

第4章

数据库安全性

在第1章中已经讲到,数据库的特点之一是由数据库管理系统提供统一的数据保护功能来保证数据的安全可靠和正确有效。数据库的数据保护主要包括数据库的安全性和完整性。本章讲解数据库的安全性,第5章将讨论数据库的完整性。

本章导读

数据库的安全性问题和计算机系统的安全性是紧密联系的,计算机系统的安全性问题可大致分为三大类,即技术安全类、管理安全类和政策法规类(详见二维码内容)。



扩展阅读: 计算机系统的三类安全性问题

本章讨论数据库技术安全类问题,即从技术上如何保证数据库系统的安全性。

本章主要介绍有关计算机信息安全和数据库安全标准的内容。从4.2节起讲解数据库安全性控制的主要技术。希望读者理解和掌握通过SQL语句实现自主存取控制权限的授予和收回的方法;掌握创建用户、角色,以及分配权限给角色的方法。要加强实验练习掌握这些方法,还要进一步理解什么是强制存取控制机制,如何利用视图技术、审计技术、数据存储加密和传输加密等技术手段提高数据库的安全性。

本章较难理解的内容是强制存取控制机制中确定主体能否存取客体的存取规则,要理解制定该存取规则的原因。

4.1 数据库安全性概述

数据库的安全性是指保护数据库,以防不合法使用所造成的数据泄露、篡改或破坏。

安全性问题不是数据库系统所独有的,所有计算机系统都存在不安全因素,只是在数据库系统中由于大量数据集中存放,而且为众多用户直接共享,数据成为一个部门、企业乃至一个国家重要的资源,从而使安全性问题更为突出。系统安全保护措施是否有效是数据库系统的主要技术指标之一。

4.1.1 数据库的不安全因素

数据库的安全性事故频发。例如,2016年初某地多所医院连续遭受勒索软件的侵害,给医院和患者带来了极大的不便,对医院的工作造成了极大的负面影响。

综合来看,对数据库安全性产生威胁的因素主要有以下几方面。

1. 非授权用户对数据库的恶意存取和破坏

一些黑客(hacker)或不法分子在用户存取数据库时窃取用户名和用户口令等信息,然后假冒合法用户获取、修改甚至破坏用户数据。有的黑客还故意锁定并修改数据,进行勒索和破坏等犯罪活动。因此,必须阻止有损数据库安全的非法操作,以保证数据免受未经授权的访问和破坏。

2. 数据库中重要或敏感的数据被泄露

黑客或敌对分子千方百计地盗窃数据库中重要或敏感的机密数据,造成数据泄露。例如,攻击者利用SQL注入(SQL injection)技术,在应用程序中事先定义好的查询语句的结尾添加额外的SQL语句,在入侵检测不严的情况下欺骗数据库服务器执行非授权的查询和操作,进行SQL注入攻击,使得机密数据被泄露、篡改或锁定,数据库数据被破坏。

3. 安全环境的脆弱性

数据库的安全性与计算机系统(包括计算机硬件、操作系统、网络系统等)的安全性是紧密联系的。操作系统安全性脆弱、网络协议安全性保障不足等都会造成数据库安全性的破坏。因此,必须加强计算机系统整体的安全性保护。随着互联网、云计算和大数据技术的发展,计算机系统的安全性问题越来越突出。为此,必须建立一套可信(trusted)计算机系统的概念和标准。只有建立了完善的可信标准,即安全标准,才能规范和指导安全计算机系统部件的生产,较为准确地测定产品的安全性能指标,满足民用和军用的不同需要。

4.1.2 安全标准简介

计算机以及信息安全技术方面有一系列安全标准,最有影响的是可信计算机系统评价标准TCSEC和工厂安全通用准则CC标准。

1. 可信计算机系统评价标准 TCSEC

1985年美国国防部(Department of Defense, DoD)正式颁布了《可信计算机系统评价标准》(trusted computer system evaluation criteria,简称TCSEC或DoD85)。1991年的TCSEC/Trusted Database Interpretation(TCSEC/TDI)又把TCSEC扩展到了数据库系统。

TCSEC/TDI根据计算机系统对各项指标的支持情况将系统划分为4组7个等级,依次是D, C(C1、C2), B(B1、B2、B3), A(A1),其系统可靠或可信程度逐渐增高,如表4.1所示。

表 4.1 TCSEC/TDI 安全级别划分

安全级别	安全指标
A1	验证设计(verified design)
B3	安全域(security domain)
B2	结构化保护(structural protection)
B1	标记安全保护(labeled security protection)
C2	受控的存取保护(controlled access protection)
C1	自主安全保护(discretionary security protection)
D	最小保护(minimal protection)

D 级：该级是最低级别。保留 D 级的目的是将一切不符合更高标准的系统都归于 D 组。

C1 级：该级只提供了非常初级的自主安全保护，能够实现对用户和数据的分离，进行自主存取控制(discretionary access control, DAC)，保护或限制用户权限的传播。

C2 级：该级是安全产品的最低档，提供受控的存取保护，即将 C1 级的 DAC 进一步细化，以个人身份注册负责，并实施审计和资源隔离。

B1 级：标记安全保护。对系统的数据加以标记，并对标记的主体和客体实施强制存取控制(mandatory access control, MAC)以及审计等安全机制。B1 级别的产品才被认为是真正意义上的安全产品，满足此级别的产品前一般多冠以“安全”(security)或“可信的”字样，作为区别于普通产品的安全产品出售。

B2 级：结构化保护。建立形式化的安全策略模型，并对系统内的所有主体和客体实施 DAC 和 MAC。

B3 级：安全域。该级的可信计算基(trusted computing base, TCB)必须满足访问监控器的要求，审计跟踪能力更强，并提供系统恢复过程。

A1 级：验证设计，即在提供 B3 级保护的同时，给出系统的形式化设计说明和验证，以确信各安全保护真正实现。

表 4.2 列出了不同安全级别对安全指标的支持情况。随着安全级别的由低到高，系统对各项安全指标的支持也从无到有。其中，□表示该级不提供对该指标的支持，■表示该级新增的对该指标的支持，▒表示该级对该指标的支持与相邻低一级的等级一样，▨表示该级对该指标的支持较下一级有所增加或改动。

TCSEC/TDI 从 4 个方面来描述安全性级别划分的指标，即安全策略、责任、保证和文档。每个方面又细分为若干项，如表 4.2 中第一、二行所示。

表 4.2 不同安全级别对安全指标的支持情况

安全指标	安全策略							责任			保证								文档				
	自主存取控制	客体重用	标记完整性	标记信息的扩散	主体敏感度标记	设备标记	强制存取控制	标识与鉴别	可信路径	审计	系统体系结构	系统完整性	屏蔽信道分析	可信设施管理	可信恢复	可安全测试	设计规范和验证	配置管理	可信分配	安全特性用户指南	可信设施手册	测试文档	设计文档
C1	■							■			■	■				■				■	■	■	
C2	▨	■						▨		■	■	■				▨				■	▨	■	■
B1	■	■	■	■			■	▨		▨	▨	■				▨	■			▨	▨	■	▨
B2	■	■	■	■	■	■	▨	■	■	▨	▨	■	■	■		▨	▨	■	■	■	▨	▨	▨
B3	▨	■	■	■	■	■	■	▨	▨	▨	■	■	▨	■	■	▨	▨	■		■	▨	■	▨
A1	■	■	■	■	■	■	■	■	■	■	■	■	▨	■	■	▨	▨	■	■	■	■	■	■

2. IT 安全通用准则 CC

自 1993 年起,多个国家组织了专门的委员会开发 IT 安全通用准则(common criteria, CC)。经过多次讨论和修订后,CC 2.1 版于 1999 年被 ISO 采用为国际标准,2001 年被我国采用作为国家标准。有关国际和我国信息安全标准发展简述,请参见二维码内容。



扩展阅读:信息安全标准发展简述

根据系统对安全保证要求的支持情况,CC 提出了评估保证级(evaluation assurance level, EAL),从 EAL1 至 EAL7 共分为 7 级,按保证程度逐渐增高。粗略而言,CC 的评估保证级与 TCSEC/TDI 的安全级别大致对应如表 4.3 所示。

表 4.3 CC 评估保证级(EAL)的划分及与 TCSEC/TDI 安全级别的对应

评估保证级	定义	TCSEC/TDI 安全级别 (近似相当)
EAL1	功能测试(functionally tested)	
EAL2	结构测试(structurally tested)	C1
EAL3	系统地测试和检查(methodically tested and checked)	C2
EAL4	系统地设计、测试和复查(methodically designed, tested and reviewed)	B1
EAL5	半形式化设计和测试(semiformally designed and tested)	B2
EAL6	半形式化验证的设计和测试(semiformally verified design and tested)	B3
EAL7	形式化验证的设计和测试(formally verified design and tested)	A1

4.2 数据库安全性控制

在计算机系统中,安全措施是一级一级层层设置的。例如,在图 4.1 所示的安全模型中,用户要求进入计算机系统时,系统首先根据输入的用户标识进行用户身份鉴别,只有合法的用户才准许进入计算机系统。对已进入系统的用户,数据库管理系统要执行安全保护,采取多种存取控制机制,目的是只允许用户执行合法操作,在用户退出系统后,根据情况还要进行安全审计。操作系统也会有自己的保护措施,读者可参考操作系统的有关书籍。对敏感数据,在传输过程中要进行加密保护,最后还应以密码形式存储到数据库中。

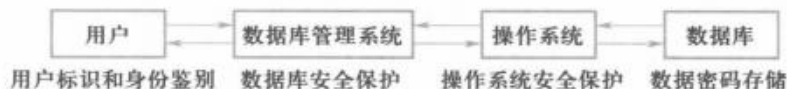


图 4.1 计算机系统的安全模型

本章讨论与数据库有关的安全性技术,对于强力逼迫透露口令、盗窃物理存储设备等行为而采取的保安措施,例如出入机房登记、加锁等,不在讨论之列。

图 4.2 是数据库管理系统的安全性控制模型示例。主要包含以下几部分:

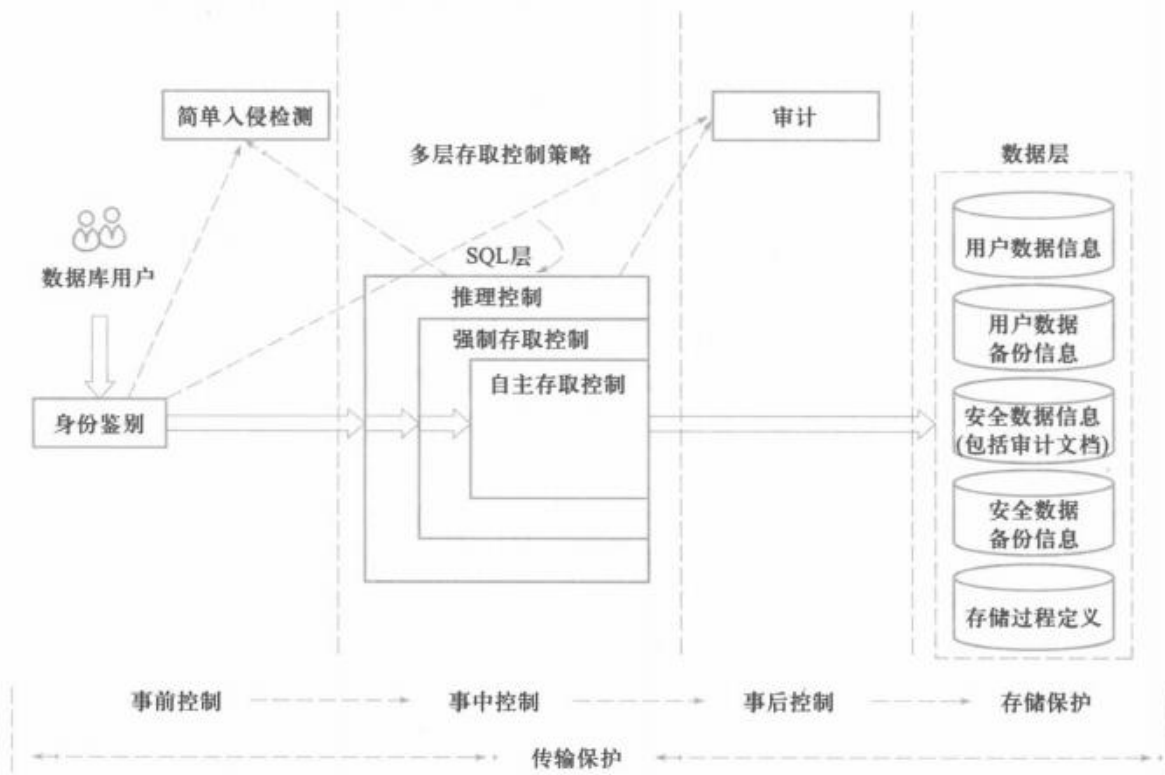


图 4.2 数据库管理系统的安全性控制模型